Center for Internet Security

CIS Microsoft Exchange Server 2016

v1.0.0 - 11-16-2015

http://benchmarks.cisecurity.org

This work is licensed under a Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International Public License. The link to the license terms can be found at https://creativecommons.org/licenses/by-nc-sa/4.0/legalcode

To further clarify the Creative Commons license related to CIS Benchmark content, you are authorized to copy and redistribute the content for use by you, within your organization and outside your organization for non-commercial purposes only, provided that (i) appropriate credit is given to CIS, (ii) a link to the license is provided. Additionally, if you remix, transform or build upon the CIS Benchmark(s), you may only distribute the modified materials if they are subject to the same license terms as the original Benchmark license and your derivative will no longer be a CIS Benchmark. Commercial use of CIS Benchmarks is subject to the prior approval of the Center for Internet Security.

Table of Contents

Table of Contents 2
Overview 5
Intended Audience 5
Consensus Guidance 5
Typographical Conventions 6
Scoring Information 6
Profile Definitions 7
Acknowledgements 9
Recommendations 10
1 Transport 10
1.1 Set 'Maximum send size - connector level' to '10240' (Not Scored) 10
1.2 Set 'Maximum receive size - organization level' to '10240' (Not Scored) 12
1.3 Set 'Enable Sender ID agent' to 'True' (Scored) 13
1.4 Set 'External send connector authentication: DNS Routing' to 'True' (Not Scored) 14
1.5 Set 'Configure Sender Filtering' to 'Enabled' (Scored) 15
1.6 Set 'Enable Sender reputation' to 'True' (Scored) 16
1.7 Set 'Maximum number of recipients - organization level' to '5000' (Scored) 17
1.8 Set 'External send connector authentication: Ignore Start TLS' to 'False' (Scored) 18
1.9 Set 'Configure login authentication for POP3' to 'SecureLogin' (Scored) 19
1.10 Set receive connector 'Configure Protocol logging' to 'Verbose' (Scored) 20
1.11 Set send connector 'Configure Protocol logging' to 'Verbose' (Scored) 21
1.12 Set 'External send connector authentication: Domain Security' to 'True' (Scored) 22
1.13 Set 'Message tracking logging - Transport' to 'True' (Scored) 24

1.14 Set 'Message tracking logging - Mailbox' to 'True' (Scored) 25

1.15 Set 'Configure login authentication for IMAP4' to 'SecureLogin' (Scored) 26

1.16 Set 'Turn on Connectivity logging' to 'True' (Scored) 27

1.17 Set 'Maximum send size - organization level' to '10240' (Scored) 28

1.18 Set 'Maximum receive size - connector level' to '10240' (Scored) 29

2 Mailbox 30

2.1 Set 'Mailbox quotas: Issue warning at' to '1991680' (Not Scored) 30

2.2 Set 'Mailbox quotas: Prohibit send and receive at' to '2411520' (Not Scored) ... 32

2.3 Set 'Mailbox quotas: Prohibit send at' to '2097152' (Not Scored) 33

2.4 Set 'Keep deleted mailboxes for the specified number of days' to '30' (Scored). 34

2.5 Set 'Do not permanently delete items until the database has been backed up' to 'True' (Scored) 35

2.6 Set 'Allow simple passwords' to 'False' (Scored) 36

2.7 Set 'Enforce Password History' to '4' or greater (Scored) 37

2.8 Set 'Password Expiration' to '90' or less (Scored) 38

2.9 Set 'Minimum password length' to '4' or greater (Scored) 39

2.10 Set 'Configure startup mode' to 'TLS' (Scored) 40

2.11 Set 'Refresh interval' to '1' (Scored) 41

2.12 Set 'Configure dial plan security' to 'Secured' (Scored) 42

2.13 Set 'Allow access to voicemail without requiring a PIN' to 'False' (Scored) 43

2.14 Set 'Retain deleted items for the specified number of days' to '14' (Scored) 44

2.15 Set 'Allow unmanaged devices' to 'False' (Scored) 45

2.16 Set 'Require encryption on device' to 'True' (Scored) 46

2.17 Set 'Time without user input before password must be re-entered' to '15' (Scored) 47

2.18 Set 'Require alphanumeric password' to 'True' (Scored) 48

2.19 Set 'Require client MAPI encryption' to 'True' (Scored) 49
2.20 Set 'Number of attempts allowed' to '10' (Scored) 50
2.21 Set 'Require password' to 'True' (Scored) 51
3 Other 52
3.1 Set cmdlets 'Turn on Administrator Audit Logging' to 'True' (Scored) 52
3.2 Set 'Require Client Certificates' to 'Required' (Not Scored) 53
3.3 Set 'Turn on script execution' to 'RemoteSigned' (Scored) 54
3.4 Set 'Turn on Administrator Audit Logging' to 'True' (Scored) 55
3.5 Set 'Enable automatic replies to remote domains' to 'False' (Scored) 56
3.6 Set 'Allow basic authentication' to 'False' (Scored) 57
3.7 Set 'Enable non-delivery reports to remote domains' to 'False' (Scored) 58
3.8 Set 'Enable OOF messages to remote domains' to 'None' (Scored) 59
3.9 Set 'Enable automatic forwards to remote domains' to 'False' (Scored) 60
3.10 Set 'Enable S/MIME for OWA 2010' to 'True' (Scored) 61
3.11 Set mailbox 'Turn on Administrator Audit Logging' to 'True' (Scored) 62
Appendix: Change History 65

Overview

This document, Security Configuration Benchmark for Microsoft Exchange Server 2016, provides prescriptive guidance for establishing a secure configuration posture for Microsoft Exchange Server 2016. This guide was tested against Microsoft Exchange Server 2016. To obtain the latest version of this guide, please visit http://benchmarks.cisecurity.org.

If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft Exchange Server 2016 on a Microsoft Windows platform.

Consensus Guidance

This benchmark was created using a consensus review process comprised of subject matter experts. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS benchmark undergoes two phases of consensus review. The first phase occurs during initial benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the benchmark. This discussion occurs until consensus has been reached on benchmark recommendations. The second phase begins after the benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the benchmark. If you are interested in participating in the consensus process, please visit https://community.cisecurity.org.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, or examples. Text should be interpreted exactly as presented.
<italic font in brackets>	Italic texts set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to denote the title of a book, article, or other publication.
Note	Additional information or caveats

Scoring Information

A scoring status indicates whether compliance with the given recommendation impacts the assessed target's benchmark score. The following scoring statuses are used in this benchmark:

Scored

Failure to comply with "Scored" recommendations will decrease the final benchmark score. Compliance with "Scored" recommendations will increase the final benchmark score.

Not Scored

Failure to comply with "Not Scored" recommendations will not decrease the final benchmark score. Compliance with "Not Scored" recommendations will not increase the final benchmark score.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **Level 1 - CAS Services Security**

  Items in this profile apply to the Client Access Server role and intend to:

  - Be practical and prudent,
  - Provide a clear security benefit, and
  - Not inhibit the utility of the technology beyond acceptable means.

- **Level 1 - Edge Services Security**

  Items in this profile apply to the Edge Server role and intend to:

  - Be practical and prudent,
  - Provide a clear security benefit, and
  - Not inhibit the utility of the technology beyond acceptable means.

- **Level 1 - Hub Services Security**

  Items in this profile apply to the Hub Server role and intend to:

  - Be practical and prudent,
  - Provide a clear security benefit, and
  - Not inhibit the utility of the technology beyond acceptable means.

- **Level 1 - Mailbox Services Security**

  Items in this profile apply to the Mailbox Server role and intend to:

  - Be practical and prudent,
  - Provide a clear security benefit, and
  - Not inhibit the utility of the technology beyond acceptable means.

- **Level 1 - UM Services Security**

  Items in this profile apply to the Unified Messaging Server role and intend to:

  - Be practical and prudent,
  - Provide a clear security benefit, and
  - Not inhibit the utility of the technology beyond acceptable means.

Acknowledgements

This benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor
Dave Colbeck

Editor
David Berube CISSP

Recommendations

1 Transport

This section contains recommendations that impact messages while they are in transit. The following PowerShell Cmdlet are covered in this section:

```
Set-SendConnector
Set-SenderFilterConfig
Set-SenderReputationConfig
Set-ReceiveConnector
Set-TransportServer
Set-TransportService
Set-TransportConfig
Set-PopSettings
Set-ImapSettings
```

1.1 Set 'Maximum send size - connector level' to '10240' (Not Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

This setting limits the total size of messages at the connector level. This includes the message header, the message body, and any attachments. For internal message flow, Exchange Server uses the custom `X-MS-Exchange-Organization-OriginalSize` message header to record the original message size of the message as it enters the Exchange Server organization. Whenever the message is checked against the specified message size limits, the lower value of the current message size or the original message size header is used. The size of the message can change because of content conversion, encoding, and agent processing.

Rationale:

This setting somewhat limits the impact a malicious user or a computer with malware can have on the Exchange infrastructure by restricting the size of incoming messages.

Audit:

Execute the following cmdlet and ensure `MaxMessageSize` is set to '10240':

```
Get-SendConnector "Connection to Contoso.com" | fl -property MaxMessageSize
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-SendConnector "Connection to Contoso.com" -MaxMessageSize 10240KB
```

Impact:

Users will not be able to send messages larger than the limit.

Default Value:

10240

1.2 Set 'Maximum receive size - organization level' to '10240' (Not Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

This limit includes the message header, the message body, and any attachments. For internal message flow, Exchange Server uses the custom `X-MS-Exchange-Organization-OriginalSize` message header to record the original message size of the message as it enters the Exchange Server organization. Whenever the message is checked against the specified message size limits, either the lower value of the current message size or the original message size header is used. The size of the message can change because of content conversion, encoding, and agent processing.

Rationale:

This setting somewhat limits the impact that a malicious user or a computer with malware can have on the Exchange infrastructure by restricting the size of incoming messages.

Audit:

Execute the following cmdlet and ensure `MaxReceiveSize` is set to '10240 ':

```
Get-TransportConfig | fl -property MaxReceiveSize
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-TransportConfig -MaxReceiveSize 10240KB
```

Impact:

Users will not be able to receive messages larger than the limit.

Default Value:

10240

1.3 Set 'Enable Sender ID agent' to 'True' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

The Sender ID agent is an antispam agent enabled on Exchange servers that perform the Edge Transport server role. Sender ID tries to verify that every e-mail message originates from the Internet domain from which it claims to have been sent. Sender ID checks the address of the server that sends the message against a registered list of servers that the domain owner has authorized to send e-mail.

Rationale:

Spam consumes a large amount of network bandwidth and server capacity. In addition, it is often the source of malicious software.

Audit:

Execute the following cmdlet and ensure `InternalSMTPServers` is set to 'True':

```
Get-SenderIDConfig | fl -property Enabled
```

Remediation:

To remediate this settings, execute the following cmdlet:

```
Set-SenderIDConfig -Enabled $true
```

Impact:

Some legitimate messages may be blocked.

Default Value:

True

1.4 Set 'External send connector authentication: DNS Routing' to 'True' (Not Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

Select this option to use DNS to route outbound mail. If enabled the connector will use DNS to resolve the IP address of the remote SMTP server.

Rationale:

Basic authentication sends credentials across the network in plaintext. DNS routing helps protect connections from tampering or interception by unauthorized users.

Audit:

Execute the following cmdlet and ensure `DNSRoutingEnabled` is set to 'True':

```
Get-SendConnector "Connection to Contoso.com" | fl -property DNSRoutingEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-SendConnector "Connection to Contoso.com" -DNSRoutingEnabled $true
```

Impact:

The organization's servers will only be able to send e-mail to remote servers that are located through DNS routing.

Default Value:

False

1.5 Set 'Configure Sender Filtering' to 'Enabled' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

By default, sender filtering is enabled on a computer performing the Edge Transport server role for inbound messages from the Internet that are not authenticated. These messages are handled as external messages. You can disable the Sender Filter agent in individual computer configurations by using the Exchange admin center or the Exchange Management Shell. When you enable the Sender Filter agent on a computer running Exchange, it filters all messages from all Receive connectors on that computer. Only messages from external sources are filtered. External sources are defined as non-authenticated sources. These are considered anonymous Internet sources.

Rationale:

Spam consumes a large amount of network bandwidth and server capacity. In addition, it is often the source of malicious software.

Audit:

Execute the following cmdlet and ensure Enabled is set to 'True':

```
Get-SenderFilterConfig | fl -property Enabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-SenderFilterConfig -Enabled $true
```

Impact:

Some legitimate messages may be blocked.

Default Value:

True

1.6 Set 'Enable Sender reputation' to 'True' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

When sender reputation is enabled on a computer, sender reputation filters all messages from all Receive connectors on that computer. Only messages from external sources are filtered. External sources are defined as non-authenticated sources, which are considered anonymous Internet sources.

Rationale:

Spam consumes a large amount of network bandwidth and server capacity. In addition, it is often the source of malicious software.

Audit:

Execute the following cmdlet and ensure `SenderBlockingEnabled` and `OpenProxyDetectionEnabled` are set to 'True':

```
Get-SenderReputationConfig | fl -property SenderBlockingEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-SenderReputationConfig -SenderBlockingEnabled $true -OpenProxyDetectionEnabled
$true
```

Impact:

Some legitimate messages may be blocked if the threshold is set too high.

Default Value:

True

1.7 Set 'Maximum number of recipients - organization level' to '5000' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

You can use this setting to control the total number of message recipients. When a message is first composed, the recipients exist in the `To:`, `Cc:`, and `Bcc:` header fields. When the message is submitted for delivery, the message recipients are converted into `RCPT TO:` entries in the message envelope. A distribution group is counted as a single recipient during message submission.

Rationale:

This setting somewhat limits the impact that a malicious user or a computer with malware can have on the Exchange infrastructure by restricting the number of recipients for any single message.

Audit:

Execute the following cmdlet and ensure `PickupDirectoryMaxRecipientsPerMessage` is set to '5000':

```
Get-TransportService -Identity "Server01" | fl -property
PickupDirectoryMaxRecipientsPerMessage
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
 Set-TransportService -Identity "Server01" -PickupDirectoryMaxRecipientsPerMessage
5000
```

Impact:

Users will not be able to send a message to more recipients than the limit.

Default Value:

5000

1.8 Set 'External send connector authentication: Ignore Start TLS' to 'False' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

If this setting is enabled then you will not be able to configure mutual authentication TLS, referred to as "External send connector authentication: Domain Security" in this baseline.

Rationale:

Basic authentication sends credentials across the network in plaintext. TLS helps protect credentials from interception by unauthorized users.

Audit:

Execute the following cmdlet and ensure `IgnoreSTARTTLS` is set to 'False':

```
Get-SendConnector -identity <connector_name> | fl -property IgnoreSTARTTLS
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
set-SendConnector -identity <connector_name> -IgnoreSTARTTLS: $false
```

Impact:

The organization's servers will only be able to send e-mail to remote servers that TLS.

Default Value:

True

1.9 Set 'Configure login authentication for POP3' to 'SecureLogin' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

POP3 transmits all data, including user credentials and potentially sensitive messages, in plaintext. Using this setting to enable TLS ensures that POP3 network traffic is encrypted, and it allows the client to verify the server's address.

Rationale:

An attacker who can intercept or eavesdrop on the POP3 traffic could view sensitive information.

Audit:

Execute the following cmdlet and ensure `SecureLogin` is set to 'SecureLogin':

```
Get-PopSettings  | fl -property LoginType
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-PopSettings -LoginType SecureLogin
```

Impact:

Clients that do not support TLS will not be able to access e-mail via POP3.

Default Value:

SecureLogin

1.10 Set receive connector 'Configure Protocol logging' to 'Verbose' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

A protocol log is a record of the SMTP activity between messaging servers as part of message delivery. This SMTP activity occurs on Send connectors and Receive connectors that are configured on Hub Transport servers and Edge Transport servers. By default, protocol logging is disabled.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Audit:

Execute the following cmdlet and ensure `ProtocolLoggingLevel` is set to 'Verbose':

```
Get-ReceiveConnector "<IDENTITY>" | fl -property ProtocolLoggingLevel
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-ReceiveConnector "<IDENTITY>" -ProtocolLoggingLevel Verbose
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

None

1.11 Set send connector 'Configure Protocol logging' to 'Verbose' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

A protocol log is a record of the SMTP activity between messaging servers as part of message delivery. This SMTP activity occurs on Send connectors and Receive connectors that are configured on Hub Transport servers and Edge Transport servers. By default, protocol logging is disabled.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Audit:

Execute the following cmdlet and ensure `ProtocolLogginglevel` is set to 'Verbose':

```
Get-SendConnector "IDENTITY" | fl -property ProtocolLoggingLevel
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-SendConnector "IDENTITY" -ProtocolLoggingLevel Verbose
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

None

1.12 Set 'External send connector authentication: Domain Security' to 'True' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

It is preferable to use Exchange Authentication or IPsec for external send connectors. However, if you must use Basic authentication to enable Domain Security, using (Mutual Auth TLS) for external send connectors helps to protect credentials and e-mail sent to other organizations.

If enabled, the Send connector will attempt to establish a mutual Transport Layer Security (TLS) connection with remote servers when sending mail. There are additional configuration steps required before you can start using TLS. For more information about how to configure mutual TLS, see [Using Domain Security: Configuring Mutual TLS].

Rationale:

Basic authentication sends credentials across the network in plaintext. Domain Security (Mutual Auth TLS) helps protect credentials from interception by unauthorized users.

Audit:

Execute the following cmdlet and ensure `DomainSecureEnabled` is set to 'True':

```
get-sendconnector -Identity <SendConnectorIdParameter> | fl DomainSecureEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
set-sendconnector -Identity <SendConnectorIdParameter> -DomainSecureEnabled $true
```

Impact:

The organization's servers will only be able to send e-mail to remote servers that support Domain Security (Mutual Auth TLS).

Default Value:

False

References:

1. http://technet.microsoft.com/en-us/library/bb123543(EXCHG.140).aspx

1.13 Set 'Message tracking logging - Transport' to 'True' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

A message tracking log provides a detailed log of all message activity as messages are transferred to and from a computer running Exchange. Message tracking is available on Hub Transport servers, Edge Transport servers, and Mailbox servers. By default, message tracking is enabled.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Audit:

Execute the following cmdlet and ensure `MessageTrackingLogEnabled` is set to 'True':

```
Get-TransportService EXCHANGE1 | fl -property MessageTrackingLogEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-TransportService EXCHANGE1 -MessageTrackingLogEnabled $true
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

True

1.14 Set 'Message tracking logging - Mailbox' to 'True' (Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

A message tracking log provides a detailed log of all message activity as messages are transferred to and from a computer running Exchange. Message tracking is available on Hub Transport servers, Edge Transport servers, and Mailbox servers. By default, message tracking is enabled.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Audit:

Execute the following cmdlet and ensure `MessageTrackingLogEnabled` is set to 'True':

```
Get-TransportService EXCHANGE1 | fl -property MessageTrackingLogEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
 Set-TransportService  EXCHANGE1 -MessageTrackingLogEnabled $true
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

True

1.15 Set 'Configure login authentication for IMAP4' to 'SecureLogin' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

IMAP4 transmits all data, including user credentials and potentially sensitive messages, in plaintext. Using this setting to enable SSL ensures that IMAP4 network traffic is encrypted, and it allows the client to verify the server's address.

Rationale:

An attacker who can intercept or eavesdrop on the IMAP4 traffic could view sensitive information.

Audit:

Execute the following cmdlet and ensure `LoginType` is set to 'SecureLogin':

```
Get-ImapSettings | fl -property LoginType
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-ImapSettings -LoginType SecureLogin
```

Impact:

Clients that do not support TLS will not be able to access e-mail via IMAP.

Default Value:

SecureLogin

1.16 Set 'Turn on Connectivity logging' to 'True' (Scored)

Profile Applicability:

- Level 1 - Edge Services Security

Description:

A connectivity log is a record of the SMTP connection activity of the outbound message delivery queues to the destination Mailbox server, smart host, or domain. Connectivity logging is available on Hub Transport servers and Edge Transport servers. By default, connectivity logging is disabled.

Rationale:

If events are not recorded it may be difficult or impossible to determine the root cause of system problems or the unauthorized activities of malicious users.

Audit:

Execute the following cmdlet and ensure `ConnectivityLogEnabled` is set to 'True':

```
Get-TransportService EXCHANGE1 | fl -property ConnectivityLogEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-TransportService EXCHANGE1 -ConnectivityLogEnabled $true
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

False

1.17 Set 'Maximum send size - organization level' to '10240' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

This limit includes the message header, the message body, and any attachments. For internal message flow, Exchange Server uses the custom `X-MS-Exchange-Organization-OriginalSize` message header to record the original message size of the message as it enters the Exchange Server organization. Whenever the message is checked against the specified message size limits, the lower value of the current message size or the original message size header is used. The size of the message can change because of content conversion, encoding, and agent processing.

Rationale:

This setting somewhat limits the impact that a malicious user or a computer with malware can have on the Exchange infrastructure by restricting the size of outgoing messages.

Audit:

Execute the following cmdlet and ensure `MaxSendSize` is set to '10240':

```
Get-TransportConfig | fl -property MaxSendSize
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-TransportConfig -MaxSendSize 10240KB
```

Impact:

Users will not be able to send a message larger than the limit.

Default Value:

10240

1.18 Set 'Maximum receive size - connector level' to '10240' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

You can use this setting to limit the total size of messages at the connector level. This includes the message header, the message body, and any attachments. For internal message flow, Exchange Server uses the custom `X-MS-Exchange-Organization-OriginalSize` message header to record the original message size of the message as it enters the Exchange Server organization. Whenever the message is checked against the specified message size limits, the lower value of the current message size or the original message size header is used. The size of the message can change because of content conversion, encoding, and agent processing.

Rationale:

This setting somewhat limits the impact a malicious user or a computer with malware can have on the Exchange infrastructure by restricting the size of incoming messages.

Audit:

Execute the following cmdlet and ensure `MaxMessageSize` is set to '10240KB':

```
Get-ReceiveConnector "Connection from Contoso.com" | fl -property MaxMessageSize
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-ReceiveConnector "Connection from Contoso.com" -MaxMessageSize 10240KB
```

Impact:

Users will not be able to receive messages larger than the limit.

Default Value:

10240

2 Mailbox

This section contains recommendations that impact mailboxes, unified messaging, address books and public folders. The following PowerShell Cmdlet are covered in this section:

```
Set-MailboxDatabase
Set-ActiveSyncMailboxPolicy
Set-UMService
Set-UMMailboxPolicy
Set-UMDialPlan
Set-CASMailbox
```

2.1 Set 'Mailbox quotas: Issue warning at' to '1991680' (Not Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

You can configure this setting to automatically warn mailbox users that their mailbox is approaching its storage limit. To specify the storage limit, select the check box for this capability, and then specify in kilobytes (KB) how much content users can store in their mailboxes before a warning e-mail message is sent to them. You can enter a value between 0 and 2,147,483,647 KB (2.1 terabytes).

Rationale:

If users exceed their mailbox limits without warning, they may miss important messages requiring them to take immediate action to mitigate a security risk.

Audit:

Execute the following cmdlet and ensure `IssueWarningQuota` is set to '1991680KB':

```
Get-MailboxDatabase "EXCHANGE01\Mailbox Database" | fl -property IssueWarningQuota
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MailboxDatabase "EXCHANGE01\Mailbox Database" -IssueWarningQuota 1991680KB
```

Impact:

Users will receive a warning when their mailboxes reach the specified value.

Default Value:

1991680

2.2 Set 'Mailbox quotas: Prohibit send and receive at' to '2411520' (Not Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

Configure this setting to prevent users from sending and receiving e-mail messages after their mailbox size reaches the specified limit. To specify this limit, select the check box, and then type the size of the mailbox in kilobytes (KB) at which you want to prohibit the sending and receiving of e-mail messages and notify the user. You can enter a value between 0 and 2,147,483,647 KB (2.1 terabytes).

Rationale:

If users exceed their mailbox limits without warning, they may miss important messages requiring them to take immediate action to mitigate a security risk.

Audit:

Execute the following cmdlet and ensure `ProhibitSendReceiveQuota` is set to '2411520KB':

```
Get-MailboxDatabase "EXCHANGE01\Mailbox Database" | fl -property
ProhibitSendReceiveQuota
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MailboxDatabase "EXCHANGE01\Mailbox Database" -ProhibitSendReceiveQuota 2411520KB
```

Impact:

Users will be unable to send or receive messages when their mailboxes reach the specified value.

Default Value:

2411520

2.3 Set 'Mailbox quotas: Prohibit send at' to '2097152' (Not Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

You can configure this setting to prevent users from sending new e-mail messages after their mailboxes reach a specified limit. To specify this limit, select the check box for this capability, and then type the size of the mailbox in kilobytes (KB) at which you want to prohibit the sending and receiving of e-mail messages and notify the user. You can enter a value between 0 and 2,147,483,647 KB (2.1 terabytes).

Rationale:

This setting prevents users from sending messages when their mailbox is approaching its size limit. However, they can continue to receive messages.

Audit:

Execute the following cmdlet and ensure `ProhibitSendQuota` is set to '2097152KB':

```
Get-MailboxDatabase "EXCHANGE01\Mailbox Database" | fl -property ProhibitSendQuota
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MailboxDatabase "EXCHANGE01\Mailbox Database"  -ProhibitSendQuota 2097152KB
```

Impact:

Users will be unable to send messages when their mailboxes reach the specified value.

Default Value:

2097152

2.4 Set 'Keep deleted mailboxes for the specified number of days' to '30' (Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

You can use this setting to specify how long deleted mailboxes are retained before they are permanently removed from the database. Defining a reasonable retention period facilitates recovering accidentally deleted mailboxes while controlling the volume of storage that retained mailboxes require.

Rationale:

Administrators may want to recover accidentally deleted mailboxes or they may need to recover deliberately deleted mailboxes for legal or managerial reasons.

Audit:

Execute the following cmdlet and ensure `MailboxRetention` is set to '30.00:00:00':

```
Get-Mailboxdatabase "EXCHANGE01\Mailbox Database" | fl -property MailboxRetention
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-Mailboxdatabase "EXCHANGE01\Mailbox Database" -MailboxRetention 30.00:00:00
```

Impact:

The impact should be small: additional storage space will be required for storing deleted mailboxes until they are purged.

Default Value:

30

2.5 Set 'Do not permanently delete items until the database has been backed up' to 'True' (Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

This setting allows you to ensure that items are not permanently deleted until the database has been backed up.

Rationale:

To ensure that accidentally deleted items can be recovered, they should not be permanently deleted until the database is backed up.

Audit:

Execute the following cmdlet and ensure `RetainDeletedItemsUntilBackup` is set to 'True':

```
Get-MailboxDatabase <Mailbox Database Name> | fl -property
RetainDeletedItemsUntilBackup
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MailboxDatabase <Mailbox Database Name> -RetainDeletedItemsUntilBackup $true
```

Impact:

The impact of enabling this setting should be minimal. More storage space will be required until any pending items are permanently deleted.

Default Value:

False

2.6 Set 'Allow simple passwords' to 'False' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can configure this setting to require strong passwords to unlock mobile devices before they can connect via ActiveSync to an Exchange server.

Rationale:

Allowing simple passwords can make it easier for an attacker to correctly guess them.

Audit:

Execute the following cmdlet and ensure `AllowSimpleDevicePassword` is set to 'False':

```
Get-MobileDeviceMailboxPolicy | fl -property AllowSimplePassword
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy <Profile> -AllowSimplePassword $false
```

Impact:

Users will be forced to use strong passwords.

Default Value:

True

2.7 Set 'Enforce Password History' to '4' or greater (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Retaining the password history ensures that old passwords will not be reused within a reasonable timeframe.

Rationale:

The longer a user uses the same password, the greater the chance that an attacker can determine the password through a brute force attack. Also, any accounts that may have been compromised will remain exploitable for as long as the password is left unchanged. If password changes are required but password reuse is not prevented, or if users continually reuse a small number of passwords, the effectiveness of a good password policy is greatly reduced. If you specify a low number for this setting, users will be able to use the same small number of passwords repeatedly.

Audit:

Execute the following cmdlet and ensure `DevicePasswordHistory` is set to '4' or greater:

```
Get-MobileDeviceMailboxPolicy | fl -property PasswordHistory
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy <Profile> -PasswordHistory 4
```

Impact:

The major impact of this setting configuration is that it requires users to create a new password every time they change an old one. Requiring users to change their passwords to new unique values increases the risk of users writing them down to not forget them. Another risk is that users may create passwords that change incrementally to make them easier to remember but also easier to guess. An example of this would be password01, password02, and so on.

Default Value:

0

2.8 Set 'Password Expiration' to '90' or less (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can configure this setting to specify how long before passwords expire and users must change them.

Rationale:

The longer a password exists the higher the likelihood that it will be compromised by a brute force attack, by an attacker gaining general knowledge about the user, or by the user sharing the password. Configuring this setting to 0 so that users are never required to change their passwords is a major security risk because doing so allows a compromised password to be used by a malicious user for as long as the valid user has authorized access to the system.

Audit:

Execute the following cmdlet and ensure `DevicePasswordExpiration` is set to '90' or less:

```
Get-MobileDeviceMailboxPolicy | fl -property PasswordExpiration
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy default -PasswordExpiration 90
```

Impact:

Configuring the value of this setting too low requires users to change their passwords very often. This can reduce security in the organization, because users might write their passwords in an unsecured location or lose them. Configuring the value of this setting too high also reduces the level of security in an organization, because it allows potential attackers more time to discover user passwords or to use compromised accounts.

Default Value:

Unlimited

2.9 Set 'Minimum password length' to '4' or greater (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can configure this setting to specify a minimum password length for device passwords. Long passwords can provide increased security. However, long passwords can decrease device usability.

Rationale:

Types of password attacks include dictionary attacks that use common words and phrases, and brute force attacks that use character combinations. Attackers also sometimes try to obtain an account database so they can use tools to discover accounts and passwords.

Audit:

Execute the following cmdlet and ensure `MinDevicePasswordLength` is set to '4' or greater:

```
Get-MobileDeviceMailboxPolicy | fl -property MinPasswordLength
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy default -MinPasswordLength 4
```

Impact:

Requirements for extremely long passwords can actually decrease the security of an organization, because users might leave password information in an unsecured location or lose it. If very long passwords are required, mistyped passwords could cause account lockouts and increase help desk calls. If your organization has issues with forgotten passwords due to password length requirements, consider teaching your users about pass phrases, which are often easier to remember and, due to the larger number of character combinations, much harder to discover.

Default Value:

4

2.10 Set 'Configure startup mode' to 'TLS' (Scored)

Profile Applicability:

- Level 1 - UM Services Security

Description:

Use this setting to start the UM Server in secure mode. This forces all dial plans to use TLS.

Rationale:

Communications between other VOIP systems and Exchange that are not protected by TLS are vulnerable to being captured by a malicious third party.

Audit:

Execute the following cmdlet and ensure `UMStartUpMode` is set to 'TLS':

```
Get-UMService -Identity Exchange1| fl -property UMStartUpMode
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-UMService -Identity Exchange1 -UMStartUpMode TLS
```

Impact:

VOIP systems that do not support TLS will be blocked from connecting to your Exchange servers after this is applied.

Default Value:

TCP

2.11 Set 'Refresh interval' to '1' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can configure this setting to specify how often in hours that policy settings should be refreshed. Refreshing the policy settings sends a fresh copy of the policy down to devices.

Rationale:

Organizational requirements change, and new vulnerabilities may be discovered, so it is likely that ActiveSync policy settings will change. For these reasons, it is important to configure a refresh interval to ensure that the latest policy settings are applied to the devices in your organization.

Audit:

Execute the following PowerShell script and ensure `DevicePolicyRefreshInterval` is set to '1:00:00'.

```
Get-MobileDeviceMailboxPolicy -Identity default| fl -property
DevicePolicyRefreshInterval
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy -Identity default -DevicePolicyRefreshInterval '1:00:00'
```

Impact:

Clients will attempt to acquire the latest policy at a shorter interval impacting server and client bandwidth.

Default Value:

Unlimited

2.12 Set 'Configure dial plan security' to 'Secured' (Scored)

Profile Applicability:

- Level 1 - UM Services Security

Description:

Use this setting to protect individual dial plans if the UM Server cannot be started in TLS Mode. To use this setting, the UM Server must be started in DUAL Mode.

Rationale:

If the UM role is not started in secure mode, each dial plan is individually vulnerable to traffic being captured by a malicious third party.

Audit:

Execute the following cmdlet and ensure `VoIPSecurity` is set to 'Secured':

```
Get-UMDialPlan -identity MySecureDialPlan | fl -property VoIPSecurity
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-UMDialPlan -identity MySecureDialPlan -VoIPSecurity Secured
```

Impact:

VOIP systems that do not support TLS will be blocked from connecting to your Exchange servers after this is applied.

Default Value:

Unsecured

2.13 Set 'Allow access to voicemail without requiring a PIN' to 'False' (Scored)

Profile Applicability:

- Level 1 - UM Services Security

Description:

Use this setting to ensure PIN access to mailbox data via voice is required.

Rationale:

If PINLess access is enabled, the mailbox data is unsecured and vulnerable to capture when being accessed via the phone

Audit:

Execute the following PowerShell cmdlet and ensure `AllowPinlessVoiceMailAccess` is set to 'False':

```
Get-UMMailboxPolicy -id MyUMMailboxPolicy | fl -property AllowPinlessVoiceMailAccess
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-UMMailboxPolicy -id MyUMMailboxPolicy -AllowPinlessVoiceMailAccess $false
```

Impact:

All mailbox data could be obtained through the voicemail system

Default Value:

False

2.14 Set 'Retain deleted items for the specified number of days' to '14' (Scored)

Profile Applicability:

- Level 1 - Mailbox Services Security

Description:

You can use this setting to specify how long deleted messages are retained before they are permanently removed from the database. Defining a reasonable retention period facilitates recovering accidentally deleted messages while controlling the volume of storage that retained messages require.

Rationale:

Users may want to recover accidentally deleted messages, or administrators may need to recover deliberately deleted messages for legal or managerial reasons.

Audit:

Execute the following PowerShell cmdlet and ensure `DeletedItemRetention` is set to '14':

```
Get-MailboxDatabase -Identity MDB2 | fl -property DeletedItemRetention
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MailboxDatabase -Identity MDB2 -DeletedItemRetention 14
```

Impact:

The impact should be small: additional storage space will be required for storing deleted messages until they are purged.

Default Value:

14

2.15 Set 'Allow unmanaged devices' to 'False' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

This setting determines whether Exchange allow devices that do not accept security policy updates from the Exchange server to use ActiveSync.

Rationale:

Unmanaged devices are more likely to not comply with an organization's security policies and to be infected by malicious software.

Audit:

Execute the following PowerShell cmdlet and ensure `AllowNonProvisionableDevices` is set to "False':

```
Get-MobileDeviceMailboxPolicy -Identity default | fl -property
AllowNonProvisionableDevices
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy -Identity default -AllowNonProvisionableDevices $false
```

Impact:

Users who configure their devices to block security policy or have devices that cannot receive security policy will be unable to use ActiveSync to connect to the server.

Default Value:

False

2.16 Set 'Require encryption on device' to 'True' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can use this setting to require device encryption. Configuring this setting to require device encryption increases security by encrypting all information on the storage cards for the device.

Rationale:

Unencrypted data on mobile devices is vulnerable to attack. Requiring ActiveSync encryption helps to minimize the risk of information being compromised in case a mobile device is lost.

Audit:

Execute the following PowerShell cmdlet and ensure RequireDeviceEncryption is set to 'True':

```
Get-MobileDeviceMailboxPolicy -Identity default | fl -property RequireDeviceEncryption
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
 Set-MobileDeviceMailboxPolicy -Identity default -RequireDeviceEncryption $true
```

Impact:

Devices that do not support data encryption will be unable to connect to Exchange servers in your organization.

Default Value:

False

2.17 Set 'Time without user input before password must be re-entered' to '15' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can configure this setting to prompt the user for a password after the user's device has been inactive for a specified period of time. For example, if you configure the time period for this setting to 15 minutes, the user must enter the device password every time it has been idle for 15 minutes. If the device has been idle less than 15 minutes, the user is not required to re-enter the password.

Rationale:

Mobile devices are often left unattended or lost in public places. Requiring devices to lock after 15 minutes minimizes the window of opportunity for an attacker to tamper with a lost or stolen device.

Audit:

Execute the following PowerShell cmdlet and ensure MaxInactivityTimeLock is set to '15':

```
Get-MobileDeviceMailboxPolicy -Identity Default | fl -property MaxInactivityTimeLock
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy -Identity Default  -MaxInactivityTimeLock 00:15:00
```

Impact:

Users must re-enter their passwords each time their devices remain idle for 15 minutes or longer.

Default Value:

15

2.18 Set 'Require alphanumeric password' to 'True' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Requiring users to include non-numeric characters in their passwords increases the strength of password security in your organization.

Rationale:

Not requiring alphanumeric passwords can make it easier for an attacker to correctly guess them.

Audit:

Execute the following PowerShell cmdlet and ensure `AlphanumericPasswordRequired` is set to 'False':

```
Get-MobileDeviceMailboxPolicy -Identity Default | fl -property
AlphanumericPasswordRequired
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy -Identity Default -AlphanumericPasswordRequired $true
```

Impact:

Users will be forced to use alphanumeric passwords.

Default Value:

False

2.19 Set 'Require client MAPI encryption' to 'True' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Certificates can reside in the certificate store on a mobile device or on a smart card. A certificate authentication method uses the Extensible Authentication Protocol (EAP) and the Transport Layer Security (TLS) protocol. During EAP-TLS certificate authentication, the client and the server prove their identities to each other. For example, an Exchange ActiveSync client presents its user certificate to the Client Access server, and the Client Access server presents its computer certificate to the mobile device to provide mutual authentication.

Rationale:

Communications between Outlook and Exchange that are sent unencrypted are vulnerable to being captured by a malicious third party.

Audit:

Execute the following PowerShell cmdlet and ensure EncryptionRequired is set to 'True'

```
Get-RpcClientAccess  | fl -property EncryptionRequired
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-RpcClientAccess -Server CAS01 -EncryptionRequired $true
```

Impact:

Client computers running earlier versions of Outlook or Outlook with profiles set to not use encryption will be blocked from connecting to your Exchange servers after this is applied.

Default Value:

False

2.20 Set 'Number of attempts allowed' to '10' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Use this setting to restrict the number of failed logon attempts a user can make.

Rationale:

There is a high risk that mobile devices will be lost or stolen. Enforcing this setting reduces the likelihood that an unauthorized user can guess the password of a device to access data stored on it.

Audit:

Execute the following PowerShell cmdlet and ensure `MaxPasswordFailedAttempts` is set to '10' or less:

```
Get-MobileDeviceMailboxPolicy -Identity Default | fl -property
MaxPasswordFailedAttempts
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy -Identity Default -MaxPasswordFailedAttempts 10
```

Impact:

If you enable this setting, a locked-out account cannot be used again until an administrator either resets it or the account lockout duration expires. This setting will likely generate additional help desk calls. In fact, locked accounts cause the greatest number of help desk calls in many organizations.

Default Value:

6

2.21 Set 'Require password' to 'True' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Passwords should be necessary to unlock mobile devices because they will help secure sensitive information stored on the devices in the event of loss or theft.

Rationale:

Allowing users to access devices without passwords means that anyone with physical access to them can view data on the devices.

Audit:

Execute the following PowerShell cmdlet and ensure `PasswordEnabled` is set to 'True':

```
Get-MobileDeviceMailboxPolicy -Identity Default | fl -property PasswordEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-MobileDeviceMailboxPolicy -Identity Default -PasswordEnabled $true
```

Impact:

Users will have to re-enter their password each time they want to use their device.

Default Value:

False

3 Other

This section contains recommendations for miscellaneous items. The following PowerShell Cmdlet are covered in this section:

```
Set-ExecutionPolicy
Set-RemoteDomain
Set-OwaVirtualDirectory
Set-AdminAuditLogConfig
```

3.1 Set cmdlets 'Turn on Administrator Audit Logging' to 'True' (Scored)

Profile Applicability:

- Level 1 - UM Services Security

Description:

Administrator audit logging is used to provide a log of the settings that are changed by administrators anywhere in the system. By default this setting is turned on to ensure discovery of configuration related security breaches.

Rationale:

Administrators may be able to reconfigure the system to expose a vulnerability with no record of the changes made.

Audit:

Execute the following cmdlet and ensure AdminAuditLogCmdlets is set to '*':

```
Get-AdminAuditLogConfig | fl -property AdminAuditLogCmdlets
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-AdminAuditLogConfig -AdminAuditLogCmdlets *
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

True

3.2 Set 'Require Client Certificates' to 'Required' (Not Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Certificates can reside in the certificate store on a mobile device or on a smart card. A certificate authentication method uses the Extensible Authentication Protocol (EAP) and the Transport Layer Security (TLS) protocol. During EAP-TLS certificate authentication, the client and the server prove their identities to each other. For example, an Exchange ActiveSync client presents its user certificate to the Client Access server, and the Client Access server presents its computer certificate to the mobile device to provide mutual authentication.

Rationale:

The default behavior of Exchange is to only require Basic Authentication. This type of authentication occurs in plaintext, which increases the possibility that an attacker could capture a user's credentials. In addition to configuring this setting to require client certificates, you can further mitigate the risk that the default behavior poses by configuring IIS to require SSL or TLS user connections to the Exchange servers in your organization.

Audit:

Please refer to the URL in the "References" section below.

Remediation:

Please refer to the URL in the "References" section below.

Impact:

Mobile devices will only be able to connect via ActiveSync if they have a trusted client certificate installed.

Default Value:

Not Configured

References:

1. http://technet.microsoft.com/en-us/library/bb266938%28v=exchg.141%29.aspx

3.3 Set 'Turn on script execution' to 'RemoteSigned' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

Use this setting to configure the script execution policy that controls what script types users can run.

Rationale:

Unsigned scripts are at greater risk of containing unauthorized code.

Audit:

Execute the following cmdlet and ensure `RemoteSigned` is set to 'RemoteSigned':

```
Get-ExecutionPolicy | fl -property  RemoteSigned
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-ExecutionPolicy RemoteSigned
```

Impact:

Extra configuration is required to setup Exchange servers to use an organization's public key infrastructure (PKI) certificates to sign scripts. In addition, a process must be established to explain how to test and sign scripts before they can run on production servers.

Default Value:

RemoteSigned

3.4 Set 'Turn on Administrator Audit Logging' to 'True' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Administrator audit logging is used to provide a log of the settings that are changed by administrators anywhere in the system. By default this setting is turned on to ensure discovery of configuration related security breaches.

Rationale:

Administrators may be able to reconfigure the system to expose a vulnerability with no record of the changes made.

Audit:

Execute the following cmdlet and ensure `AdminAuditLogEnabled` is set to 'true':

```
Get-AdminAuditLogConfig | fl -property AdminAuditLogEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-AdminAuditLogConfig -AdminAuditLogEnabled $True
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

True

3.5 Set 'Enable automatic replies to remote domains' to 'False' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

You can use this setting to determine if the server automatically replies to remote domains.

Rationale:

Attackers can use automated messages to determine whether a user account is active, in the office, traveling, and so on. An attacker might use this information to conduct other types of attacks.

Audit:

Execute the following cmdlet and ensure `AutoReplyEnabled` is set to 'False':

```
Get-RemoteDomain -Identity Default | fl -property AutoReplyEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-RemoteDomain -Identity Default -AutoReplyEnabled $false
```

Impact:

Remote users will not receive automated reply messages.

Default Value:

False

3.6 Set 'Allow basic authentication' to 'False' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

Use this setting to determine whether you want to allow clients to use basic authentication.

Rationale:

The default behavior of Exchange is to only require Basic Authentication. This type of authentication occurs in plaintext, which increases the possibility that an attacker could capture a user's credentials. In addition to configuring this setting to require client certificates, you can further mitigate the risk that the default behavior poses by configuring IIS to require SSL or TLS user connections to the Exchange servers in your organization.

Audit:

Execute the following cmdlet and ensure `BasicAuthentication` is set to 'False':

```
Get-OwaVirtualDirectory -Identity "owa (Default Web Site)" | fl -property
BasicAuthentication
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-OwaVirtualDirectory -Identity "owa (Default Web Site)" -BasicAuthentication $false
```

Impact:

Mobile devices will only be able to connect via ActiveSync if they do not use basic authentication.

Default Value:

True

3.7 Set 'Enable non-delivery reports to remote domains' to 'False' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

You can use this setting to determines if the server automatically sends delivery reports to remote domains.

Rationale:

Attackers can use automated messages to determine whether a user account is active, in the office, traveling, and so on. An attacker might use this information to conduct other types of attacks.

Audit:

Execute the following cmdlet and ensure `NDREnabled` is set to 'False':

```
Get-RemoteDomain -Identity Contoso  | fl -property NDREnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-RemoteDomain -Identity Contoso -NDREnabled $false
```

Impact:

Remote users will not receive automated non-delivery reports.

Default Value:

True

3.8 Set 'Enable OOF messages to remote domains' to 'None' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

You can use this setting to determine if the server automatically forwards out-of-office messages to remote domains.

Rationale:

Attackers can use automated messages to determine whether a user is active, in the office, traveling, and so on. An attacker might use this information to conduct other types of attacks.

Audit:

Execute the following cmdlet and ensure `AllowedOOFType` is set to 'None':

```
Get-RemoteDomain "RemoteDomain" | fl -property AllowedOOFType
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-RemoteDomain "RemoteDomain" -AllowedOOFType None
```

Impact:

Remote users will not receive automated out-of-office messages.

Default Value:

External

3.9 Set 'Enable automatic forwards to remote domains' to 'False' (Scored)

Profile Applicability:

- Level 1 - Hub Services Security

Description:

You can use this setting to determine if the server sends automatic forwards to remote domains.

Rationale:

Attackers can use automated messages to determine whether a user account is active, in the office, traveling, and so on. An attacker might use this information to conduct other types of attacks.

Audit:

Execute the following cmdlet and ensure `AutoForwardEnabled` is set to 'False':

```
Get-RemoteDomain -Identity Contoso | fl -property AutoForwardEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-RemoteDomain -Identity Contoso -AutoForwardEnabled $false
```

Impact:

Remote users will not receive automated forward messages.

Default Value:

False

3.10 Set 'Enable S/MIME for OWA 2010' to 'True' (Scored)

Profile Applicability:

- Level 1 - CAS Services Security

Description:

You can enable this setting to allow users to download the S/MIME control to read and create signed and encrypted messages.

Rationale:

S/MIME uses digital signatures and encryption to protect against several classes of attacks including eavesdropping, impersonation, and tampering.

Audit:

Execute the following cmdlet and ensure `SMimeEnabled` is set to 'True':

```
 Get-OWAVirtualDirectory -identity "owa (Default Web Site)" | fl -property
SMimeEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-OWAVirtualDirectory -identity "owa (Default Web Site)" -SMimeEnabled $true
```

Impact:

Users will be able to use the S/MIME control when accessing their e-mail via OWA.

Default Value:

True

3.11 Set mailbox 'Turn on Administrator Audit Logging' to 'True' (Scored)

Profile Applicability:

- Level 1 - UM Services Security

Description:

Administrator audit logging is used to provide a log of the settings that are changed by administrators anywhere in the system. By default this setting is turned on to ensure discovery of configuration related security breaches.

Rationale:

Administrators may be able to reconfigure the system to expose a vulnerability with no record of the changes made.

Audit:

Execute the following cmdlet and ensure `AdminAuditLogEnabled` is set to 'True':

```
Get-AdminAuditLogConfig | fl -property AdminAuditLogEnabled
```

Remediation:

To implement the recommended state, execute the following PowerShell cmdlet:

```
Set-AdminAuditLogConfig -AdminAuditLogEnabled $true
```

Impact:

The impact should be small: additional storage space will be required and some processing power will be used to track and record information.

Default Value:

True

Control		Set Correctly	
		Yes	No
1	**Transport**		
1.1	Set 'Maximum send size - connector level' to '10240' (Not Scored)	☐	☐
1.2	Set 'Maximum receive size - organization level' to '10240' (Not Scored)	☐	☐
1.3	Set 'Enable Sender ID agent' to 'True' (Scored)	☐	☐
1.4	Set 'External send connector authentication: DNS Routing' to 'True' (Not Scored)	☐	☐
1.5	Set 'Configure Sender Filtering' to 'Enabled' (Scored)	☐	☐
1.6	Set 'Enable Sender reputation' to 'True' (Scored)	☐	☐
1.7	Set 'Maximum number of recipients - organization level' to '5000' (Scored)	☐	☐
1.8	Set 'External send connector authentication: Ignore Start TLS' to 'False' (Scored)	☐	☐
1.9	Set 'Configure login authentication for POP3' to 'SecureLogin' (Scored)	☐	☐
1.10	Set receive connector 'Configure Protocol logging' to 'Verbose' (Scored)	☐	☐
1.11	Set send connector 'Configure Protocol logging' to 'Verbose' (Scored)	☐	☐
1.12	Set 'External send connector authentication: Domain Security' to 'True' (Scored)	☐	☐
1.13	Set 'Message tracking logging - Transport' to 'True' (Scored)	☐	☐
1.14	Set 'Message tracking logging - Mailbox' to 'True' (Scored)	☐	☐
1.15	Set 'Configure login authentication for IMAP4' to 'SecureLogin' (Scored)	☐	☐
1.16	Set 'Turn on Connectivity logging' to 'True' (Scored)	☐	☐
1.17	Set 'Maximum send size - organization level' to '10240' (Scored)	☐	☐
1.18	Set 'Maximum receive size - connector level' to '10240' (Scored)	☐	☐
2	**Mailbox**		
2.1	Set 'Mailbox quotas: Issue warning at' to '1991680' (Not Scored)	☐	☐
2.2	Set 'Mailbox quotas: Prohibit send and receive at' to '2411520' (Not Scored)	☐	☐
2.3	Set 'Mailbox quotas: Prohibit send at' to '2097152' (Not Scored)	☐	☐
2.4	Set 'Keep deleted mailboxes for the specified number of days' to '30' (Scored)	☐	☐
2.5	Set 'Do not permanently delete items until the database has been backed up' to 'True' (Scored)	☐	☐
2.6	Set 'Allow simple passwords' to 'False' (Scored)	☐	☐
2.7	Set 'Enforce Password History' to '4' or greater (Scored)	☐	☐

2.8	Set 'Password Expiration' to '90' or less (Scored)	☐	☐
2.9	Set 'Minimum password length' to '4' or greater (Scored)	☐	☐
2.10	Set 'Configure startup mode' to 'TLS' (Scored)	☐	☐
2.11	Set 'Refresh interval' to '1' (Scored)	☐	☐
2.12	Set 'Configure dial plan security' to 'Secured' (Scored)	☐	☐
2.13	Set 'Allow access to voicemail without requiring a PIN' to 'False' (Scored)	☐	☐
2.14	Set 'Retain deleted items for the specified number of days' to '14' (Scored)	☐	☐
2.15	Set 'Allow unmanaged devices' to 'False' (Scored)	☐	☐
2.16	Set 'Require encryption on device' to 'True' (Scored)	☐	☐
2.17	Set 'Time without user input before password must be re-entered' to '15' (Scored)	☐	☐
2.18	Set 'Require alphanumeric password' to 'True' (Scored)	☐	☐
2.19	Set 'Require client MAPI encryption' to 'True' (Scored)	☐	☐
2.20	Set 'Number of attempts allowed' to '10' (Scored)	☐	☐
2.21	Set 'Require password' to 'True' (Scored)	☐	☐
3	**Other**		
3.1	Set cmdlets 'Turn on Administrator Audit Logging' to 'True' (Scored)	☐	☐
3.2	Set 'Require Client Certificates' to 'Required' (Not Scored)	☐	☐
3.3	Set 'Turn on script execution' to 'RemoteSigned' (Scored)	☐	☐
3.4	Set 'Turn on Administrator Audit Logging' to 'True' (Scored)	☐	☐
3.5	Set 'Enable automatic replies to remote domains' to 'False' (Scored)	☐	☐
3.6	Set 'Allow basic authentication' to 'False' (Scored)	☐	☐
3.7	Set 'Enable non-delivery reports to remote domains' to 'False' (Scored)	☐	☐
3.8	Set 'Enable OOF messages to remote domains' to 'None' (Scored)	☐	☐
3.9	Set 'Enable automatic forwards to remote domains' to 'False' (Scored)	☐	☐
3.10	Set 'Enable S/MIME for OWA 2010' to 'True' (Scored)	☐	☐
3.11	Set mailbox 'Turn on Administrator Audit Logging' to 'True' (Scored)	☐	☐

Appendix: Change History

Date	Version	Changes for this version
11-16-15	1.0.0	Initial Release